

# Intruders and password protection

---

---

---

# Contents

- Intrusion and intruder
  - Intrusion techniques
  - Intrusion prevention and detection
  - Password management
  - UNIX scheme
  - Password selection strategies
  - How to choose secure password.
  - References
-

---

# Intrusion

- Entrance by force or without permission or welcome.
  - Any set of actions that attempt to compromise the integrity, confidentiality or availability of a resource.
  - The intentional insertion of electromagnetic energy into transmission paths in any manner with the objective of deceiving operators or of causing confusion.
-

---

# Intruder

Someone who intrudes on the privacy or property of another without permission.



---

# Intrusion Techniques

- The objective of the intruder is to gain access to a system or to increase the range of privileges accessible on a system.
  - system must maintain a file that associates a password with each authorized user.
-

---

# Intrusion Techniques

- The password file can be protected in one of two ways:
    - ❑ One-way function: The system stores only the value of a function based on the user's password. When the user presents a password, the system transforms that password and compares it with the stored value.
    - ❑ Access control: Access to the password file is limited to one or a very few accounts.
-

---

# Intrusion Techniques

- Number of password crackers, reports the following techniques for learning passwords:
    - ❑ Try default passwords used.
    - ❑ Try all short passwords (those of one to three characters).
    - ❑ Try words in the system's online dictionary or a list of likely passwords.
-

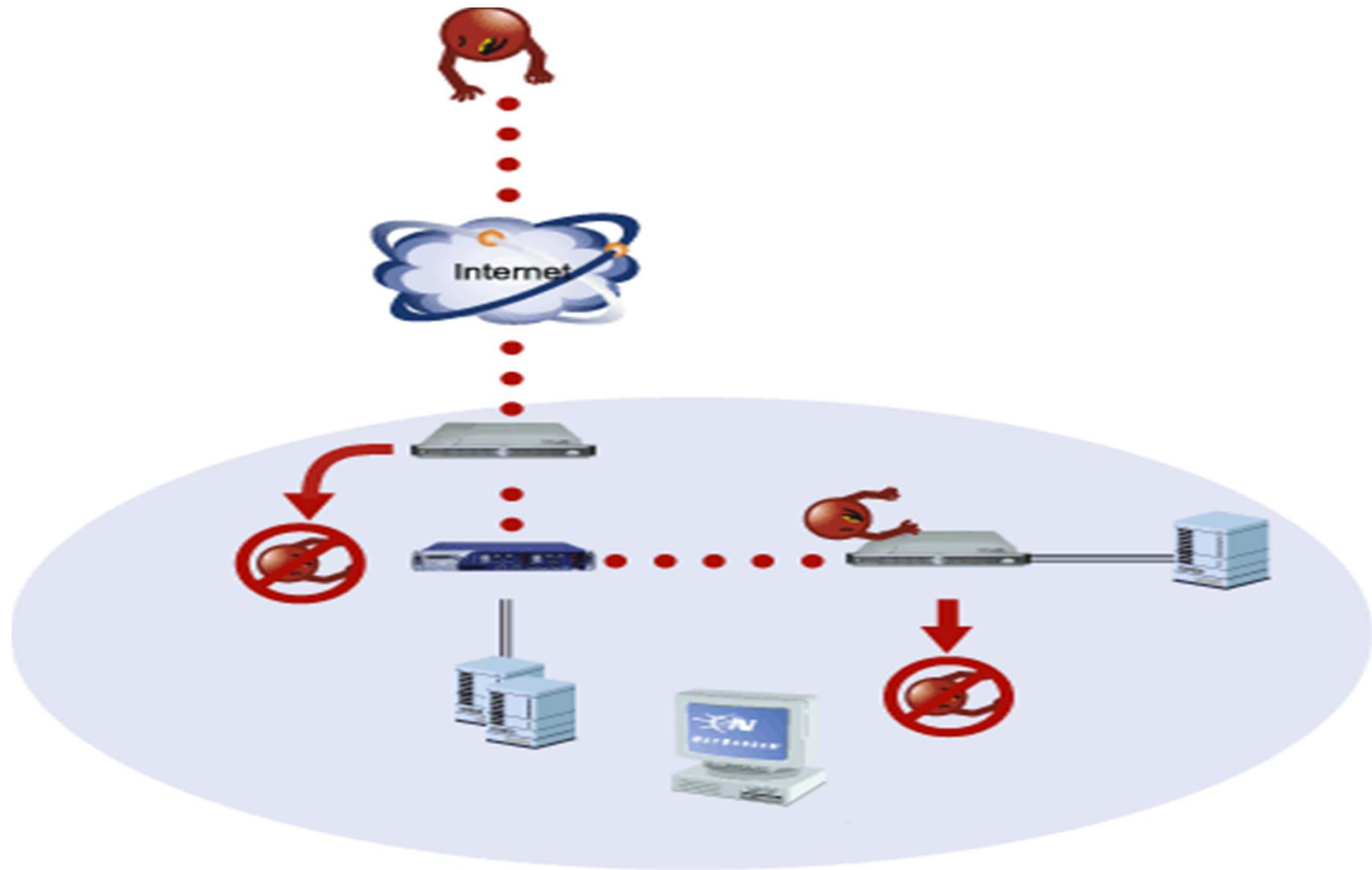
---

# Intrusion Techniques

- ❑ Collect information about users, such as their full names.
  - ❑ Try users' phone numbers, social security numbers, and room numbers.
  - ❑ Use a Trojan horse.
-



# Intrusion prevention and detection



---

# Intrusion prevention and detection

- The best intrusion prevention system will fail. A system's second line of defense is intrusion detection, and this has been the focus of much research in recent years.
  - Intruder Detection is Novell's way of tracking invalid password attempts.
-

---

# Intrusion detection approaches

- **Statistical anomaly detection:** Involves the collection of data relating to the behavior of legitimate users over a period of time. Then statistical tests are applied to observed behavior to determine with a high level of confidence whether that behavior is not legitimate user behavior.
-

---

# Intrusion detection approaches

- **Rule-based detection:** Involves an attempt to define a set of rules that can be used to decide that a given behavior is that of an intruder.



---

# Password Management

- **Password Protection:** The front line of defense against intruders is the password system. Virtually all multiuser systems require that a user provide not only a name or identifier (ID) but also a password. The password serves to authenticate the ID of the individual logging on to the system. In turn, the ID provides security in the following ways:
-

---

# Password Management

- The ID determines whether the user is authorized to gain access to a system.
  - The ID determines the privileges accorded to the user.
-

---

# Password Management

- The Vulnerability of Passwords: let us consider a scheme that is widely used on UNIX:
    - ❑ Each user selects a password up to eight characters.
    - ❑ This is converted into a 56-bit value (key input to an encryption routine).
    - ❑ The encryption routine is based on DES. The DES algorithm is modified using a 12-bit.
    - ❑ This value is related to the time at which the password is assigned to the user.
-

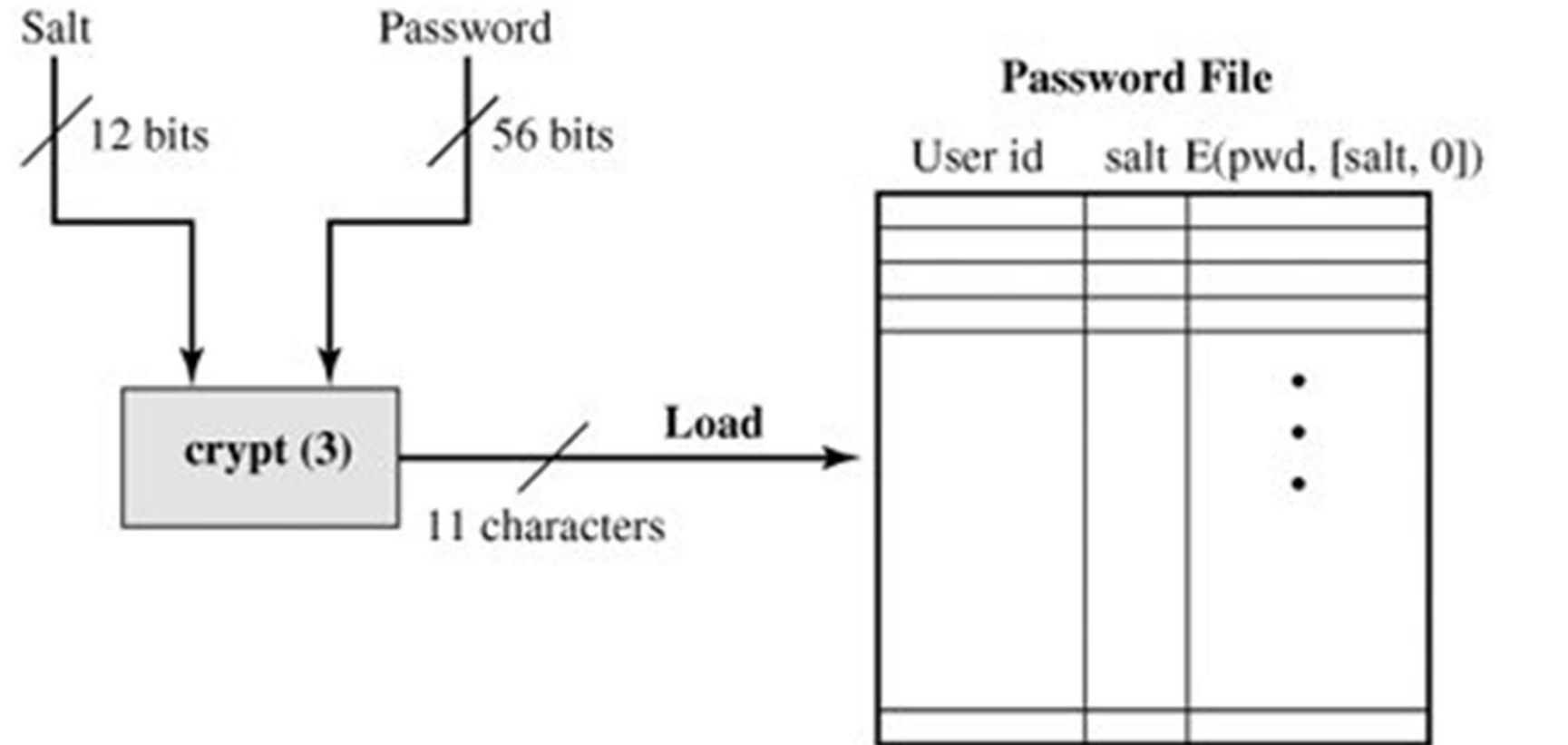
---

# Password Management

- ❑ The modified DES algorithm is exercised with a data input consisting of a 64-bit block of zeros.
  - ❑ The output of the algorithm then serves as input for a second encryption.
  - ❑ This process is repeated for a total of 25 encryptions.
  - ❑ The resulting 64-bit output is then translated into an 11-character sequence.
  - ❑ The hashed password is then stored, together with a plaintext copy of the salt, in the password file
-

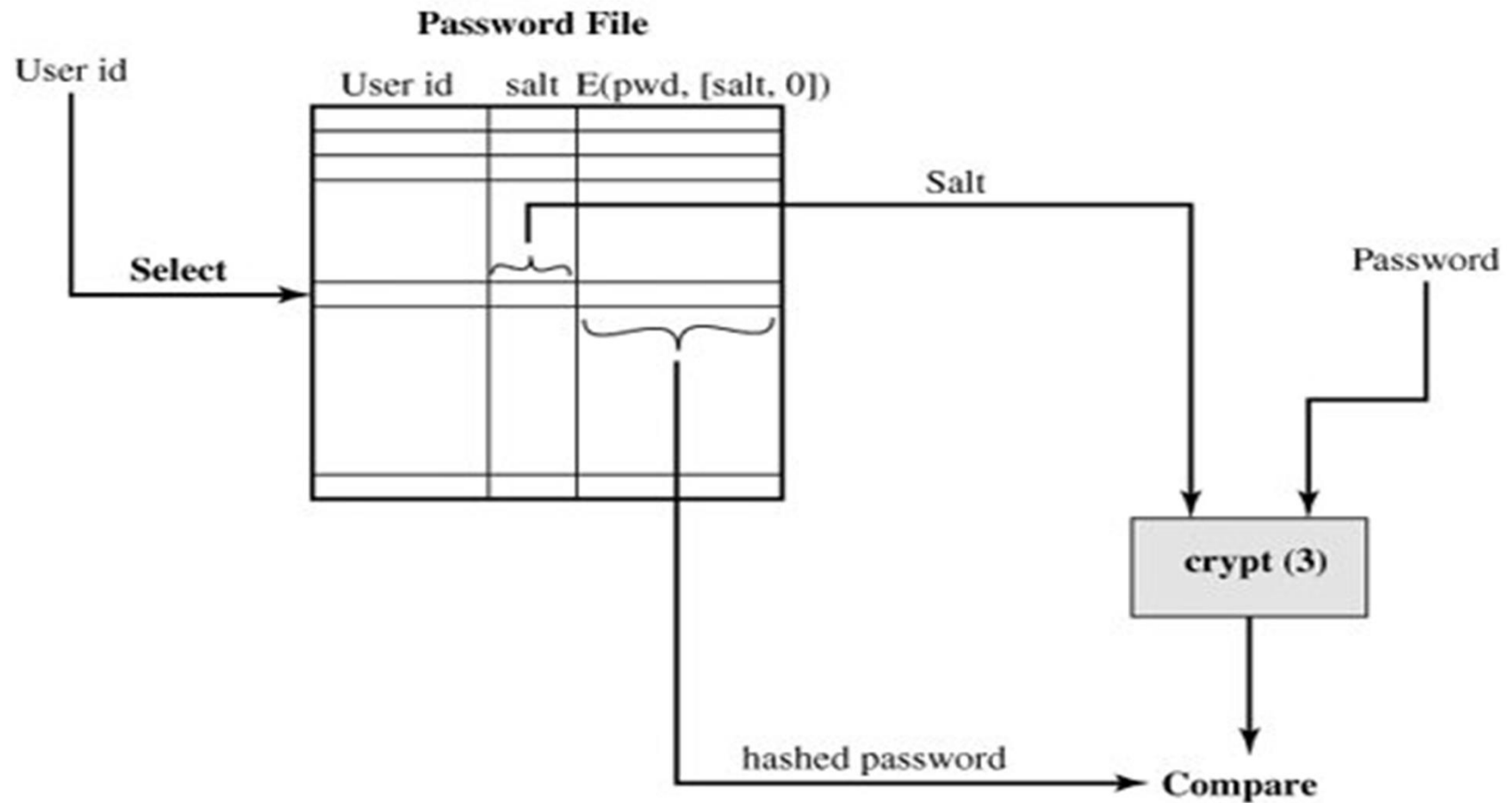


# Password Management



(a) Loading a new password

# Password Management



(b) Verifying a password

---

# Password Management

- The salt serves three purposes:
    - ❑ It prevents duplicate passwords from being visible in the password file.
    - ❑ It effectively increases the length of the password without requiring the user to remember additional characters.
-

---

# Password Management

- Access Control: One way to thwart a password attack is to deny the opponent access to the password file. If the encrypted password portion of the file is accessible only by a privileged user, then the opponent cannot read it without already knowing the password of a privileged user.
-

---

# Password Management

- Password Selection Strategies: The goal is to eliminate guessable passwords while allowing the user to select a password that is memorable. Four basic techniques are in use:
    - ❑ User education.
    - ❑ Computer-generated passwords.
    - ❑ Reactive password checking.
    - ❑ Proactive password checking.
-

---

# Password Management

- User education

- ❑ Users can be told the importance of using hard-to-guess passwords and can be provided with guidelines for selecting strong passwords.

- Computer-generated passwords

- ❑ passwords are quite random in nature

- Reactive password checking

- ❑ the system periodically runs its own password cracker to find guessable passwords. The system cancels any passwords that are guessed
-

---

# Password Management

- Proactive password checking

- ❑ user is allowed to select his or her own password.  
However, at the time of selection, the system checks to see if the password is allowable and, if not, rejects it.
  - ❑ The trick with a proactive password checker is to strike a balance between user acceptability and strength.
-

---

# Password Management

- Proactive password checking approaches:
    - Rule enforcement:
      - All passwords must be at least eight characters long.
      - The passwords must include at least one each of uppercase, lowercase, numeric digits, and punctuation marks.
    - Another possible procedure is simply to compile a large dictionary of possible "bad" passwords.
-

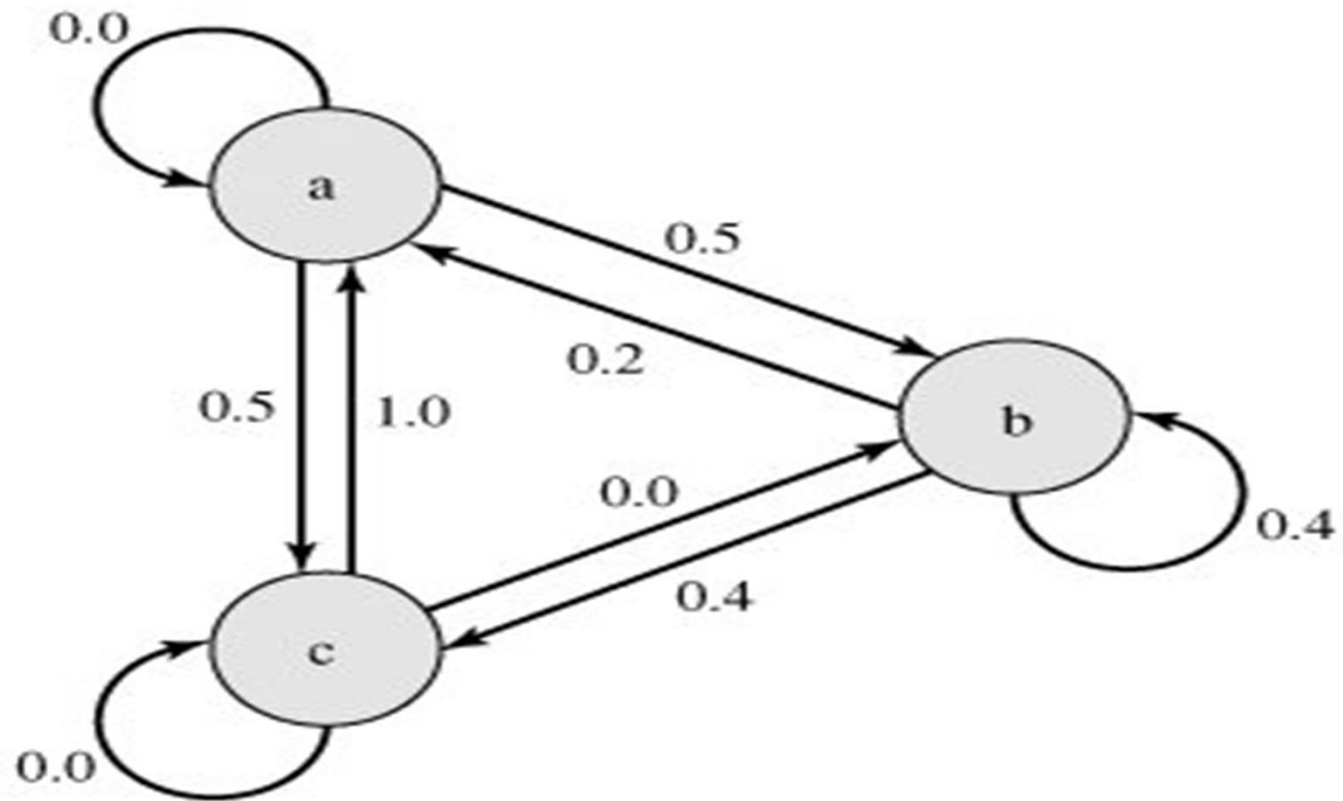


---

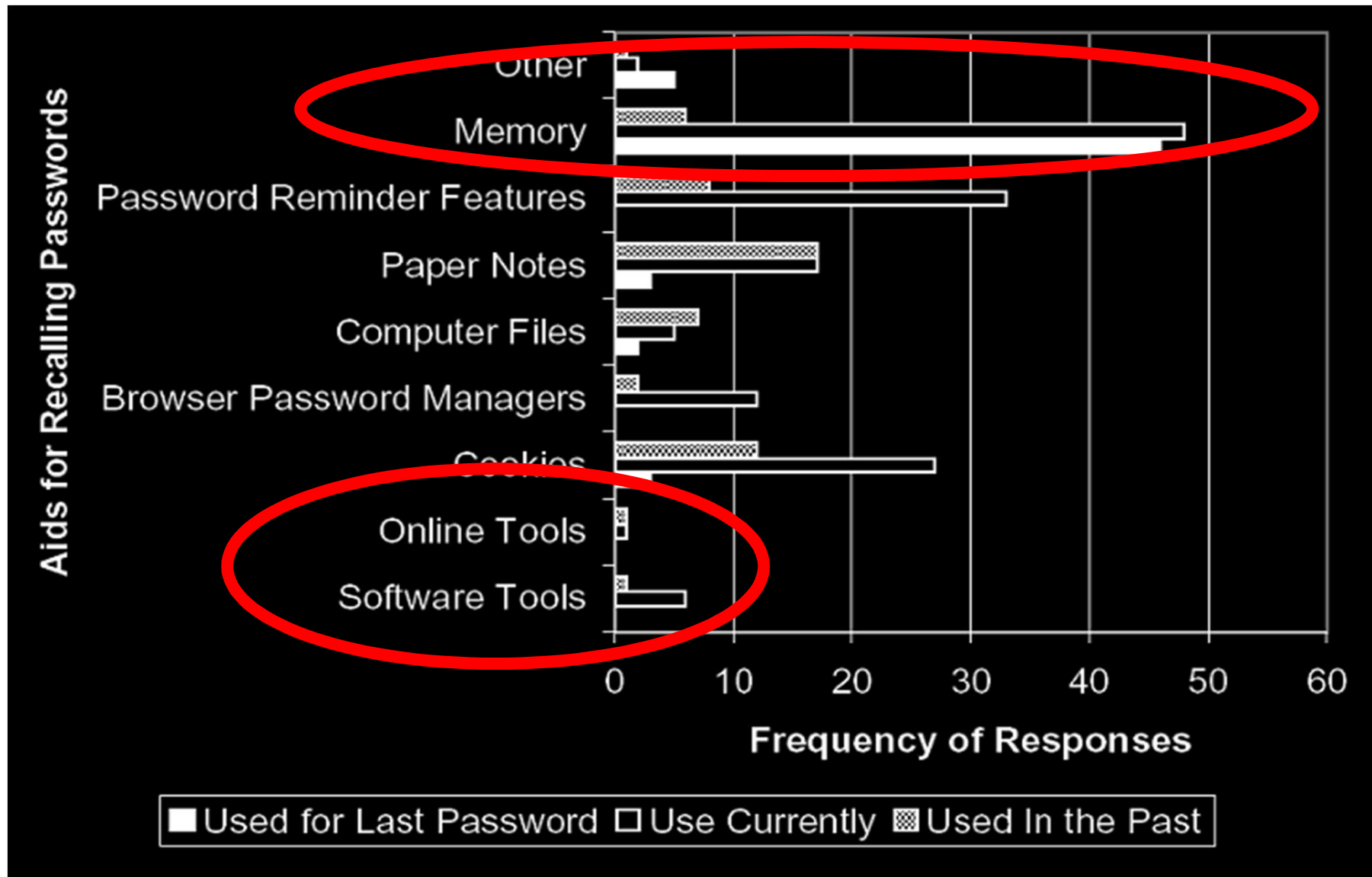
# Password Management

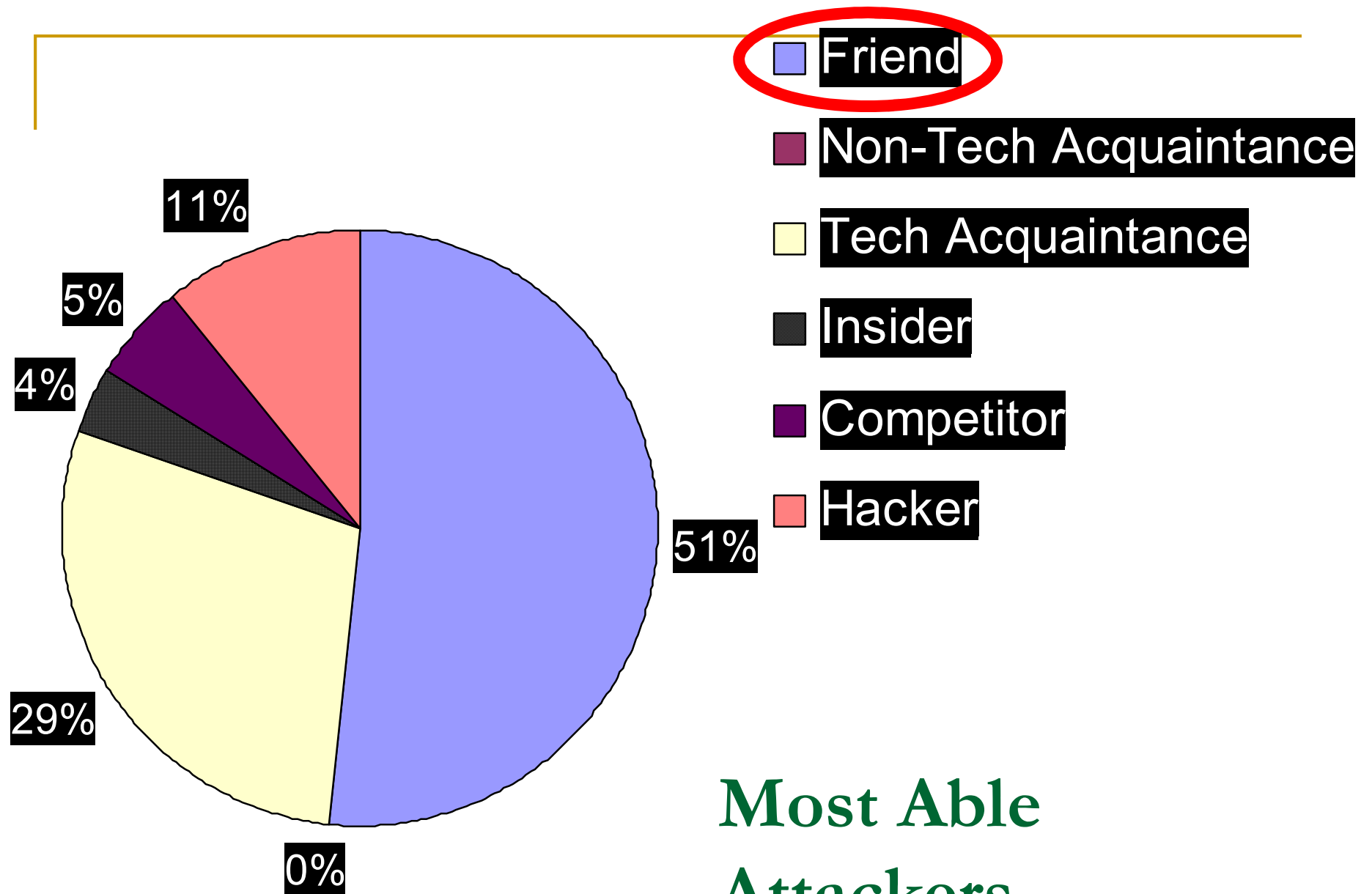
- Proactive password checker techniques
    - Markov model: generation of guessable passwords, this model shows a language consisting of an alphabet of three characters. The state of the system at any time is the identity of the most recent letter. The value on the transition from one state to another represents the probability that one letter follows another. Thus, the probability that the next letter is b, given that the current letter is a, is 0.5.
-

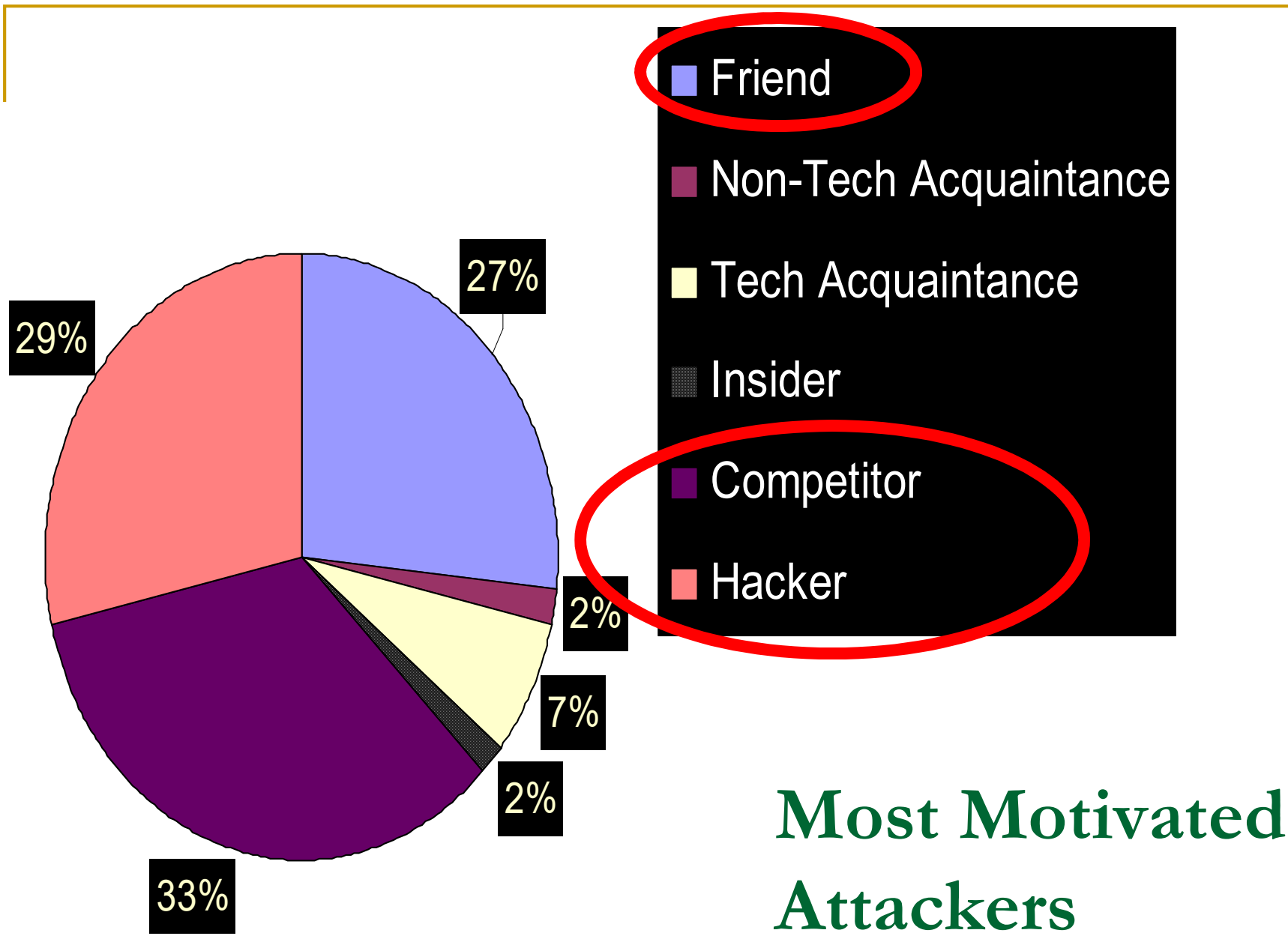
# Password Management



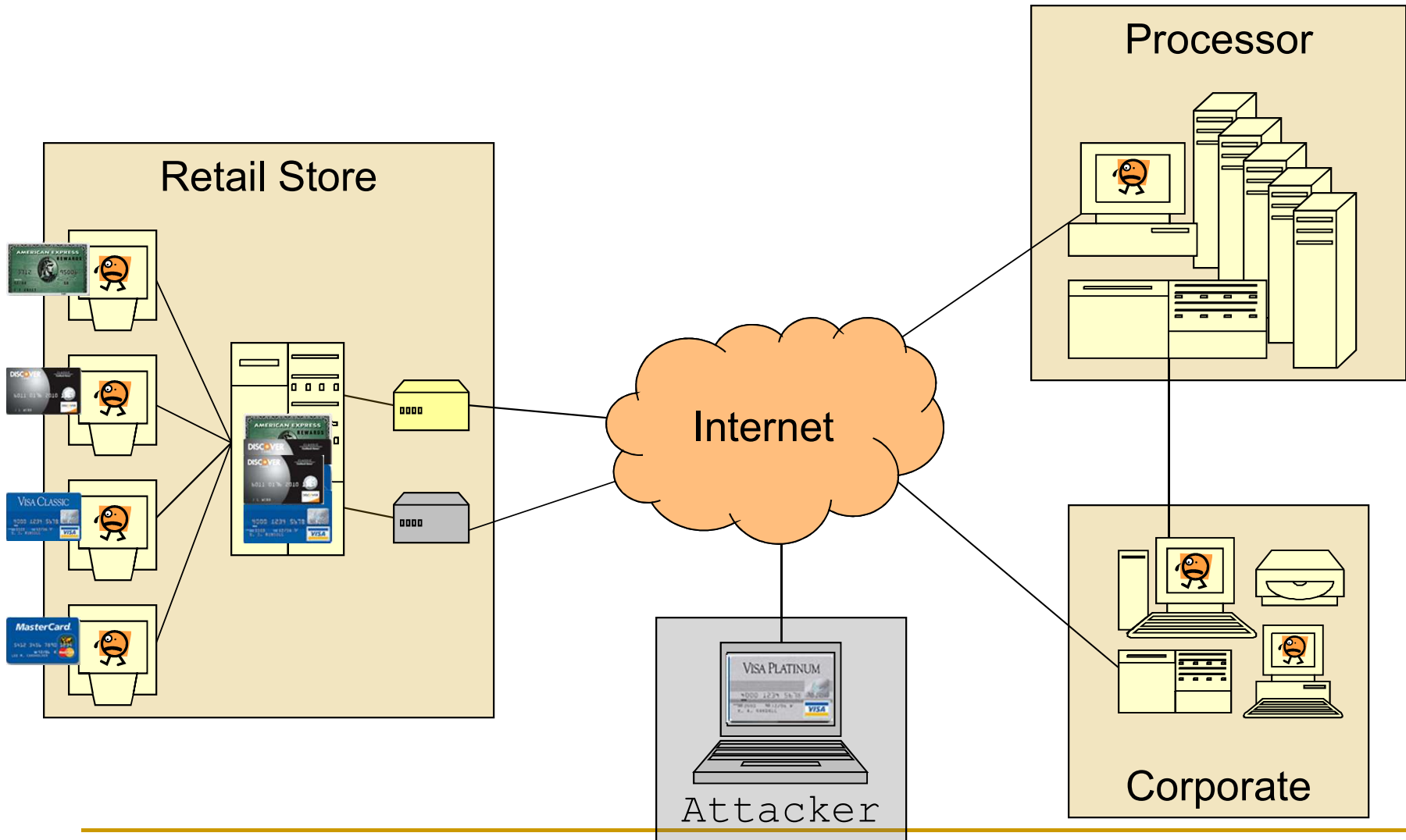
# Password reuse







# Payment Services



---

# How to Choose a secure password?

- Do NOT use words or phrases that have personal significance.
  - Mix letters, numbers and symbols, and use case sensitivity
  - Try to memorize the password, and avoid writing it down
  - Do not use the same password for everything
  - Use a password manager (PM). It is a utility that creates an encrypted file where your passwords are stored.
  - Try to use "nonsense words."
  - Do not tell anybody your password.
-

---

# Conclusion

- We need password because of the widespread adoption of computer networks, and particularly the Internet, has enabled electronic access to almost every possible service: e-mail, e-commerce, banking and government services. But with this access has come the need to identify the users of these services, both to safeguard personal information and to control the capabilities given to each user.
  - An encrypted password database is likely to be much more secure than a notebook or a wallet.
-



---

# Conclusion

- Because of the difficulties associated with remembering passwords, a group of software applications, called password keepers or password managers has emerged. These applications deal with everything from the simple storage of user IDs and passwords to the management of password access across many users.
  - Poor encryption or use of a weak master password, allowing the contents to be accessed.
-